Capstone 2 Proposal

Mentor : Professor. LAY Leangsros

Project Name : DFIR - Rapid

Project Team Members :

- Mao Sophanit
- Thy Dayuth
- Thin Panha
- Houn Sreynuth

Institution : Cambodia Academy of Digital Technology

Content Table 1

I. Executive Summary 2

1.1. What we delivered in Capstone 1 3

1.2. What Capstone 2 adds 3

II. Solution Add-On 3

2.1. Feature and Services 4

Prepare 4

Respond 5

Recover and Report 5

III. Technical Approach and Workflow 5

3.1. Operation Workflow 6

3.2. Standard Of Procedure 6

3.3. Standard and Compliance 8

IV. Demonstration Plan 8

4.1. Scenario 1: "Cloud Credential Hijack & Data Siphon" (Subscriber Client) 8

4.2. Scenario 2: "The Infostealer Leak" (Walk-in Client) 9

V. Business Model 10

5.1. Business Model Canvas 10

5.2. Revenue pillars 11

5.3. Marketing Strategies 12

5.4. Targets 12

I. Executive Summary

Capstone 2 transitions DFIR-Rapid into a working, customer-facing platform with a live website and automated lead pipeline to capture, notify, and track prospects, alongside court-ready forensic reports aligned with ISO/IEC 27037 standards.

1.1. What we delivered in Capstone 1

- **Business case:** problem statement (SMEs cannot afford in-house security or traditional DFIR consultancies), mission, vision and values (integrity, automation, accessibility).
- **Market and industry analysis:** ASEAN SME digitization, rising attacks, regulatory pressure (breach reporting windows of 24 to 72 hours), and a competitive map against CrowdStrike/SentinelOne, local consultants and DIY tools.
- **Service design:** five service offerings (Incident Response, Digital Forensics, Malware and Evidence Analysis, Business Impact Assessment, Reporting and Recovery Roadmap).
- **Service Level Agreement:** P1 to P4 response times (4 hours to 7 days), scope, NDA, data retention (12 months), liability, chain of custody and termination terms.
- **Operations:** a five-step investigation flow (Intake, Triage, Evidence Collection, Analysis, Reporting) and a tool stack of Autopsy, FTK Imager, Volatility, Chainsaw, ELK, Any.run, VirusTotal, MISP, OpenCTI and TheHive.
- **Marketing and finance:** customer segments, positioning, marketing mix, growth plan, setup cost of $4,800 to $9,000, monthly operating cost of $2,200 to $4,300 and a break-even target of about 20 cases per year.
- **Proof of work:** a recorded attack scenario with a Unified Forensic Report.

1.2. What Capstone 2 adds

- Website for customer services. ( )
- Operate Forensic on 4 Platforms: Mobile, OS, Cloud and Disk.
    - 1 Demo and 4 Procedure Document.
- Automated functional web portal for client to interact (contract, service purchases …)
- Demonstration on selected and past incident as scenario
    - Operation from start to finish.
    - Technical Forensics (Extract and analyze in depth).
- Package add on function for more customization to client needs rather than fixed package.
- Compliance and proper policy establishment documents. (Evidence handling follows ISO/IEC 27037 instead of plain “Court-Readied”).

II. Solution Add-On

2.1. Feature and Services

Add-ons are grouped by incident phase:

- Prepare (before)
- Respond (during)
- Recover and Report (after)

Prepare		
Add-on	**Client gets**	**Effort**
Compromise assessment	Standard Assessment	Medium
Log readiness setup	Audit logging turned on (M365, Google, AWS, Windows) so evidence exists	Low
Pre-staged collector	Collection kit installed and allowlisted in advance	Low
SME starter package	Readiness kit plus a basic IR policy	Low
Incident Cost Calculator	Web page where owners estimate loss	Low
Cyber readiness assessment (full)	Deeper review beyond the onboarding questionnaire	Medium
Tabletop exercise	Simulated incident to train staff	Medium
Phishing simulation	Monthly test emails	Medium
Workshops and training	Paid half-day sessions	Medium

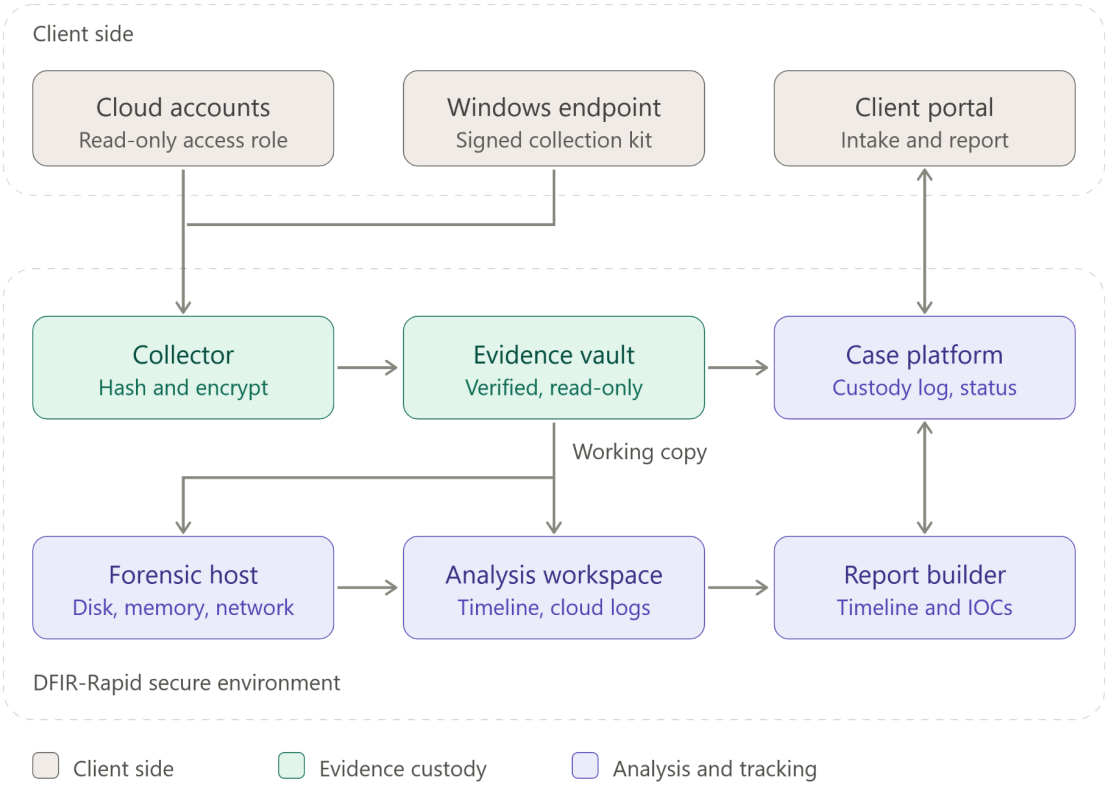
Malicious File Bot Scanning	Can use the telegram bot to check file via telegram from our services	Medium

Respond		
Add-on	**Client gets**	**Effort**
Cloud evidence collection	AWS, M365, or Google logs pulled through the API	Medium
Evidence collection only	Collection without the full investigation	Low
Report from existing evidence	Report built from evidence the client already holds	Low
Priority response upgrade	A faster P1 window, for example 2h instead of 4h	Medium

Recover and Report		
Add-on	**Client gets**	**Effort**
Post-Incident Checkup	Scan 30 days after closure plus an "all clear" letter	Medium
Notification and comms pack	Draft notices for regulators, customers and staff (Khmer and English)	Medium

III. Technical Approach and Workflow

3.1. Operation Workflow



High Level Workflow

The Basic Workflow : Collect -> Store -> Copy -> Analyze (Forensics) -> Track -> Deliver

1. Collect : the cloud is pulled through a read-only role, and the endpoint uses a signed collection kit (triage, memory, network capture, disk image). Both land at the collector, where everything is hashed on arrival and encrypted.
2. Store : the vault verifies each hash and keeps the originals read-only. Nobody analyzes the originals.
3. Copy : only a working copy leaves the vault. It goes to the forensic host (disk, memory, network captures) and to the analysis workspace (cloud logs and timelines).
4. Track : the case platform records each hash, who touched what and the status.
5. Deliver : the report builder pulls the hash list and status from the case, and the finished report to the client.

3.2. Standard Of Procedure

No	Step	Owner	Key actions	Output
0	Pre engagement	Coordinator	Signed NDA, authorization listing the systems in scope, named contact, collection role or script allowlisted. Subscribers: completed before any incident. Walk-ins: completed at Step 1 through one combined e-signature, with the kit allowlisted at collection time.	Authorization on file
1	Intake and triage	Coordinator, Analyst	Open case with a unique ID, rate priority (P1-P4), assign one investigator, start the SLA clock after authorization and deposit	Case plus priority
2	Containment guidance	Analyst	Tell the client to isolate machines and not reboot or wipe, revoke sessions or disable accounts, preserve logs. Never disable their security tools without written approval	Containment checklist signed off
3	Evidence collection	Analyst, Engineer supports	Collect cloud logs and endpoint artifacts (memory, network capture, triage files, disk image if time allows), in order of volatility, hash at source, upload, verify on receipt, log custody	Hash manifest, custody log
4	Analysis	Analyst	Ingest the working copy, build the timeline, identify IOCs, root cause, and affected data, then check findings against raw logs	Findings and timeline
5	Reporting	Analyst writes, second reviewer checks	Generate the report (summary, timeline, evidence list, root cause, impact, recommendations), peer review, publish to client, walk the client through it.	Unified Forensic Report

6	Closure	Coordinator, Founders	Client confirms receipt, evidence retained 12 months then deleted, deletion certified, lessons noted. For walk-in conversions, offer subscription, log readiness setup, and 30-day re-check.	Closed case

Important Note :

- Work only on copies and hash everything.
- Only the assigned investigator touches the evidence.
- Log each action in the case.
- Write in the report only what the evidence supports, with limits stated.

3.3. Standard and Compliance

- **ISO/IEC 27037** : Evidence collection and preservation.
- **NIST SP 800-61 Rev. 3** : Incident Response Recommendations and Considerations for Cybersecurity Risk Management.
- **MITRE ATT&CK** : Timelines and IOCs in the report.
- **ISO/IEC 27001** : Apply relevant controls.

IV. Demonstration Plan

The demo runs two scenarios : one subscriber client and one walk-in client. Both start from a client report process till getting the final reports.

4.1. Scenario 1: "Cloud Credential Hijack & Data Siphon" (Subscriber Client)

Cloud infrastructure compromise via leaked IAM credentials resulting in privilege escalation, unauthorized storage bucket exfiltration, and resource tampering.

Client Context: 40 staff Phnom Penh e-commerce SaaS platform on the Managed Subscriber tier.

Objective: Trace unauthorized cloud API calls, determine the compromised identity chain, calculate the blast radius of exfiltrated data and deliver a cloud remediation and hardening report.

1. **Initial Vector**: A threat actor acquires valid, long-term cloud administrative access keys (IAM credentials) harvested from a contractor's infostealer infection or exposed via a public test repository lacking MFA enforcement and IP whitelisting.

2. **Execution & Enumeration**: The attacker invokes cloud APIs via the CLI to enumerate tenant permissions, exploiting an overly permissive inline policy in a flat cloud architecture to elevate themselves to full administrative rights.

3. **Exfiltration**: The attacker queries storage buckets, locates customer database backups and executes an automated synchronization script to siphon hundreds of gigabytes over unmonitored egress paths before modifying bucket policies and terminating compute instances.

4. **Incident Trigger**: The cloud provider triggers an automated anomaly alert for abnormal outbound egress bandwidth and root-level policy modifications, prompting the subscriber's IT lead to click "Report Incident".

5. **Artifact Acquisition**: The response team pulls cloud management plane audit logs, object-level storage telemetry and network traffic records.

    a. **Tools**: AWS CloudTrail (or Azure Activity Logs), Amazon Athena / jq (log parsing), S3 Server Access Logs, VPC Flow Logs, Prowler / ScoutSuite (open-source posture assessment), Timeline Explorer.

6. **Analysis & Deliverable**: DFIR analysis reconstructs the API execution timeline from initial authentication to bulk egress, correlates source IPs against threat intelligence, verifies the exact list of accessed database objects and outputs the final Cloud Incident Report with key revocation proof, S3 bucket policy hardening and least-privilege IAM baselines.

4.2. Scenario 2: "The Infostealer Leak" (Walk-in Client)

Host compromise by a dummy payload that emulates RedLine Stealer behavior, resulting in simulated credential exfiltration and unauthorized account access. All data is dummy data in an isolated lab. No live malware and no real credentials are used.

Client Context: 25-staff creative agency in Phnom Penh, with no prior onboarding, monitoring or logging.

Objective: Identify the entry vector, collect host and network forensic artifacts, determine the compromised data scope, and generate a client remediation report.

7. **Initial Vector**: A graphic designer downloads a Trojanized utility (a fake PDF converter) from a malicious sponsored search result and runs the installer. This is a benign dummy executable hosted on a fake download page.

8. **Execution & Enumeration**: The dummy payload runs from %LocalAppData%\Temp and creates a hidden staging folder. It writes a dummy system profile and dummy browser credentials and cookies, plus a dummy Telegram session folder, then adds a Run key for persistence. It does not read any real browser database.

9. **Exfiltration**: The dummy files are compressed into a temporary archive. The payload beacons every 60 seconds and sends the archive over HTTP to an external C2 IP, a Python listener on Kali. Real RedLine uses SOAP over TCP or HTTP.

10. **Incident Trigger**: The business owner receives an unauthorized login alert for the company's primary marketing account from overseas and calls the hotline. This is a scripted trigger in the demo.

    a. **Walk-in onboarding**: The case is opened and rated P1. One e-signature covers the NDA, terms and system authorization, and the deposit is paid at the burst rate. The SLA clock starts here.

    b. **Containment**: The client resets passwords and revokes sessions from a clean device. The laptop is disconnected but not rebooted.

11. **Artifact Acquisition**: The triage collector extracts host evidence and network captures. Everything is hashed at source and verified on receipt, with a chain of custody log.

    a. **Tools**: KAPE, FTK Imager, Wireshark / tcpdump, WinPmem / DumpIt, Plaso / log2timeline, Timeline Explorer, TheHive.

12. **Analysis & Deliverable**: Work is done on copies only. The analysis correlates the binary hash with prefetch and memory, maps the execution timeline to the beacon and archive upload, identifies the scope of the dummy data taken (browser logins, cookies and Telegram session), confirms the Run key persistence, and checks findings against a hidden lab-only Sysmon/Splunk log.

    a. The final Incident Report contains an executive summary, a timeline, an evidence list with hashes, root cause, IOCs and impact. It also includes the ATT&CK mapping (T1204.002, T1555.003, T1539, T1560.001, T1547.001, T1041) and password revocation priorities: the marketing account, all browser-saved logins, active sessions, Telegram sessions, and 2FA, then reimaging the laptop and enabling MFA everywhere.

13. **Walk-in conversion**: The client is offered a subscription, the log readiness setup add-on and a 30-day post-incident re-check.

V. Business Model

5.1. Business Model Canvas

BMC Component	Details
Key Partners	IT Service Providers & Managed Service Providers (MSPs), Local Law Enforcement / Regulatory Bodies, Cloud Providers (AWS, Google, Microsoft), Academic Institutions (CADT).
Key Activities	Incident Response & Digital Forensics, Automated Triage & Evidence Collection, Security Auditing & Readiness Assessments, Platform & Infrastructure Maintenance.
Key Resources	Forensic Analysts & Engineers, Automated Lead & Evidence Pipeline (Supabase, n8n, TheHive), Proprietary Toolkits & Open-Source Forensics Stack, ISO/IEC 27037 & NIST Compliant Workflows.
Value Propositions	Affordable, enterprise-grade DFIR tailored for SMEs; Rapid response SLAs (hours instead of days); Automated intake and

	seamless customer onboarding; Legally defensible, evidence handling aligned with ISO/IEC 27037.
Customer Relationships	High-touch dedicated support during incidents, Automated portal updates & alerts, Post-incident reviews & retainer transitions, Community workshops & threat advisories.
Channels	Direct B2B sales outreach, Online Client Portal / Web Intake, Partner referrals & MSP channels, Industry events, webinars & social media.
Customer Segments	SMEs with 10–200 employees (e-commerce, fintech, NGOs), Cambodian businesses expanding into broader ASEAN markets, Walk-in clients requiring urgent pay-per-incident response.
Cost Structure	Initial setup ($4,800–$9,000), Monthly operations ($2,200–$4,300), Web hosting, domain, and infrastructure services, Staff salaries & continuous training.
Revenue Streams	Monthly retainer subscriptions ($200–$500/mo), Pay-per-incident investigations ($500–$5,000), Add-on security readiness packages & training.

DFIR-Rapid keeps the Capstone 1 bi-pillar model (subscriptions plus pay-per-incident); the website and lead pipeline now act as the sales engine that feeds both pillars.

5.2. Revenue pillars

Pillar	What the client gets	Price (Capstone I)
Basic tier	Triage, incident snapshot, summary report	$500 - $800
Standard tier	Full investigation and Unified Forensic Report	$1,500 - $2,500
Premium tier	Full investigation plus compliance and legal support	$3,000 - $5,000
Monthly subscription	Forensic readiness, monitoring support, priority response	$200 - $500 / Month
Pay / Incident	One-time investigation	$1,500 per incident
Individual Platform Forensics	• Mobile Forensic • OS Forensic • Cloud Forensic	Defining …

	• Disk Forensic	
Evidence collection only	Forensically sound acquisition	$500
Report from existing evidence	Report generation	$300

Price may slightly change in the future once decided on the local and standard pricing with helping SME in consideration.*

5.3. Marketing Strategies

1. **Attract:** LinkedIn, Facebook, webinars and partner referrals send SMEs to the website.
2. **Capture:** the "Request Demo" form stores every prospect in Supabase.
3. **Respond:** Team notified and replies to the visitor instantly, with follow-up within estimated SLA.
4. **Convert:** a free pilot or demo turns the lead into a per-incident or subscription client.
5. **Deliver:** the team executes rapid triage, contains the threat, and provides an actionable forensic report.
6. **Retain:** per-incident clients are offered a subscription after the case closes to prevent recurrence.

5.4. Targets

Year	Cases	Average revenue per case	Revenue
Year 1	5 to 10	$1,500	$7,500 to $15,000
Year 2	15 to 25	$2,000	$30,000 to $50,000
Year 3	40 to 55	$2,500	$100,000 to $137,500

To offset the $39,000 annual operating cost, the business must secure a minimum of 20 paid cases per year (2,000$/case).